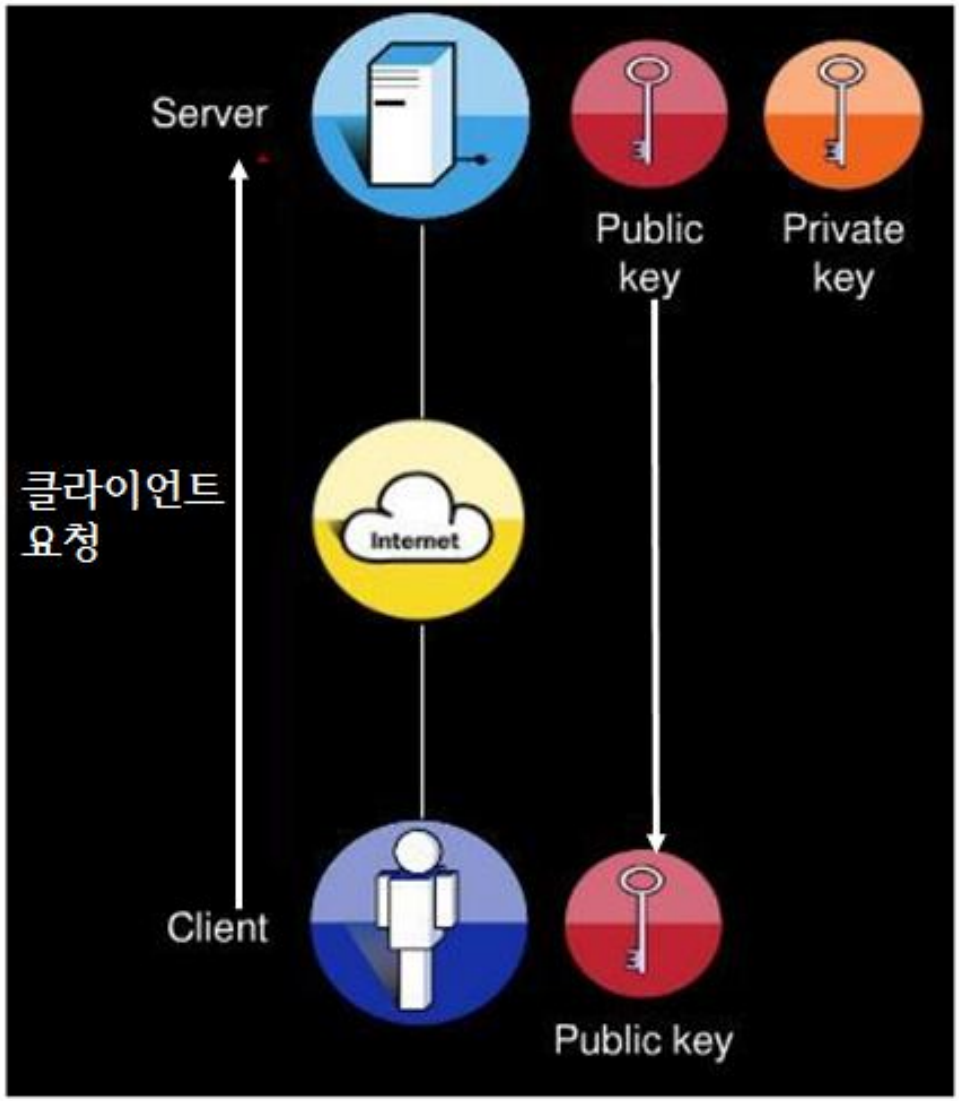
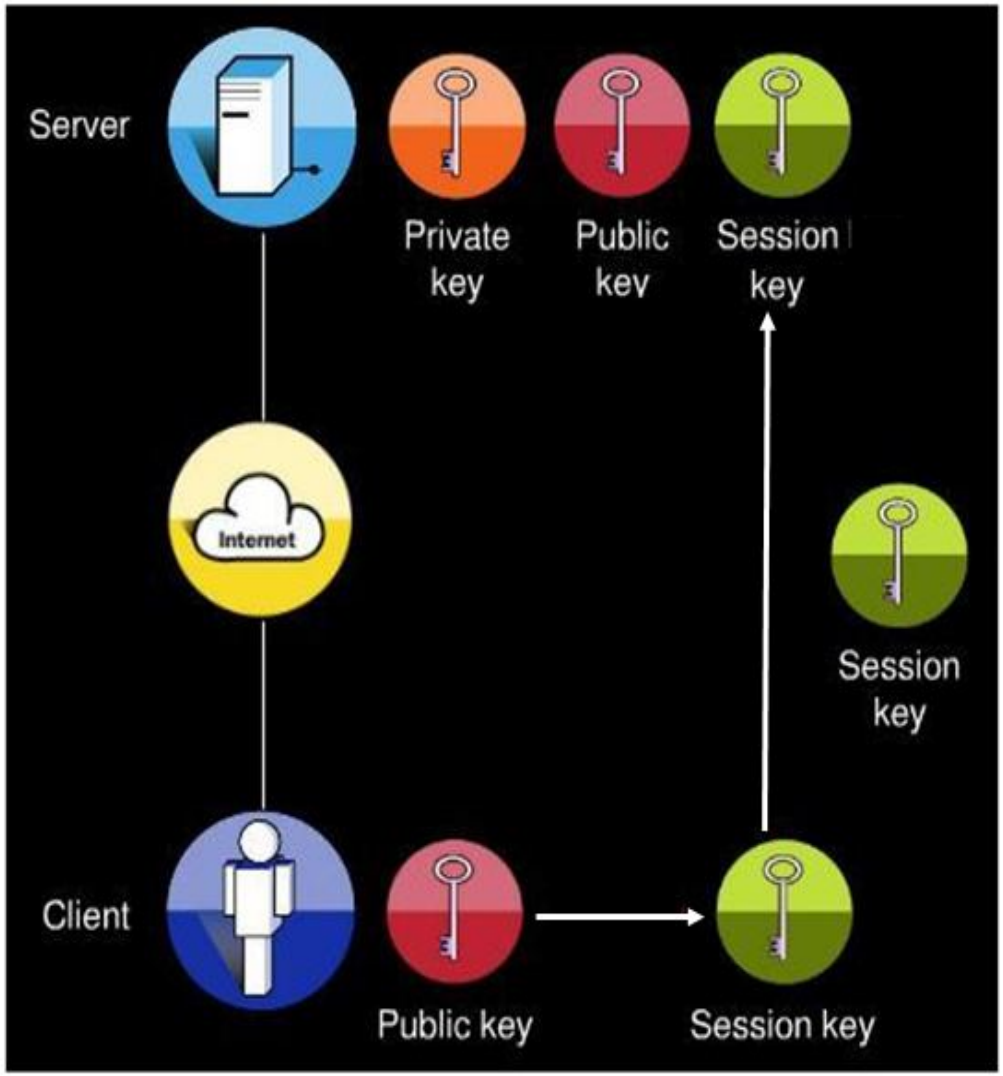
SSL & X.509

네트워크 현황분석과 이상징후 분석

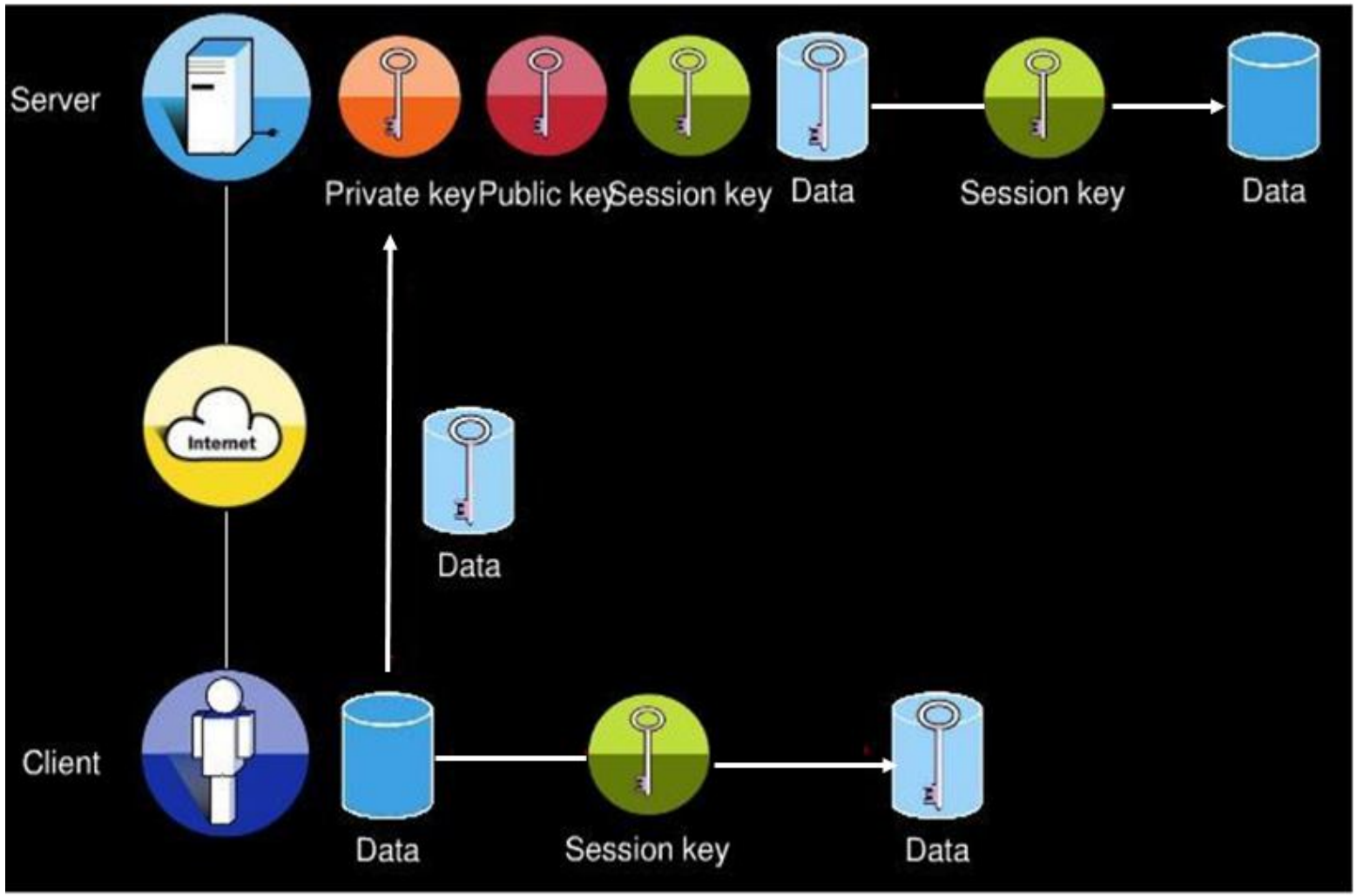
1. SSL/TLS Processing(1/3)

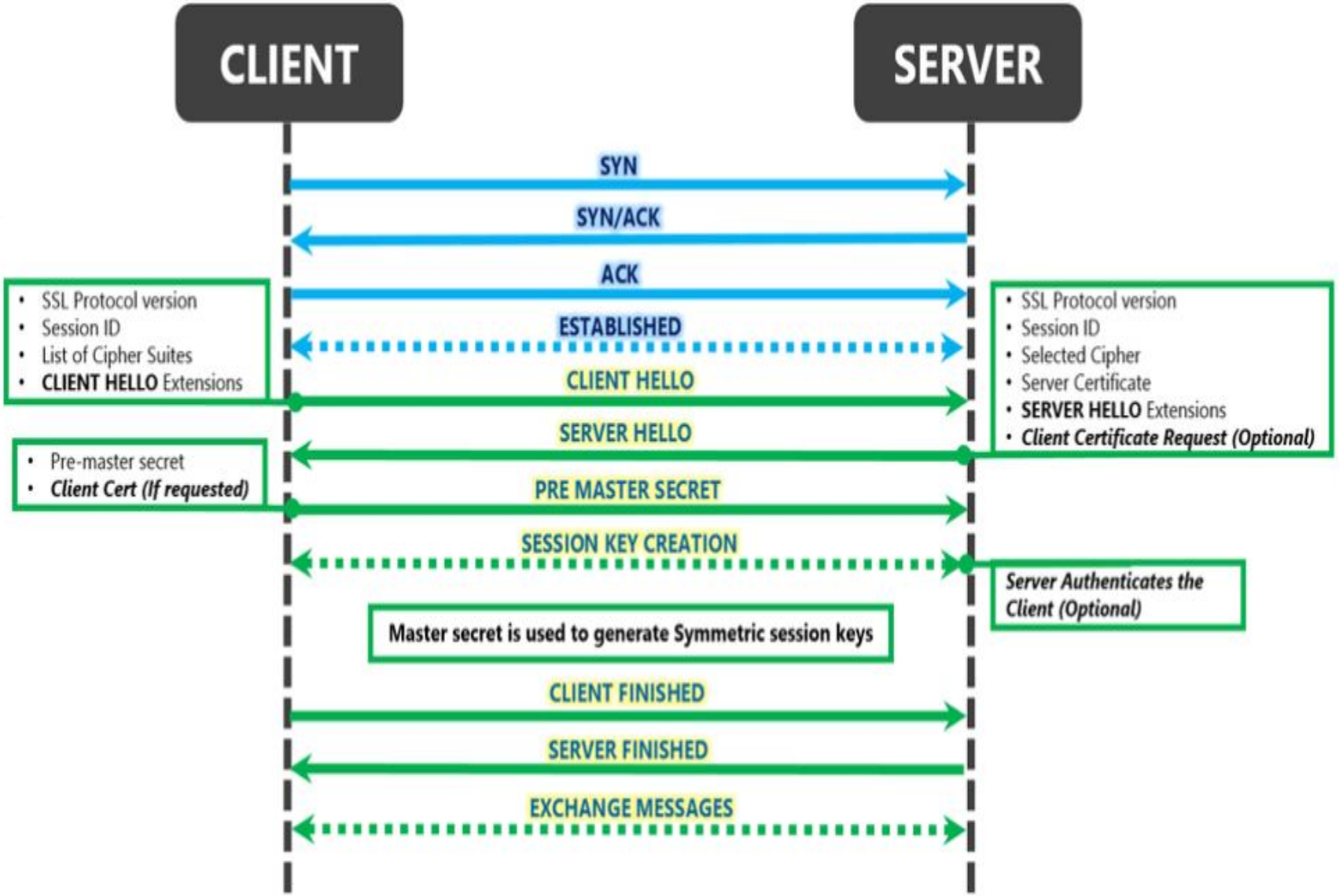


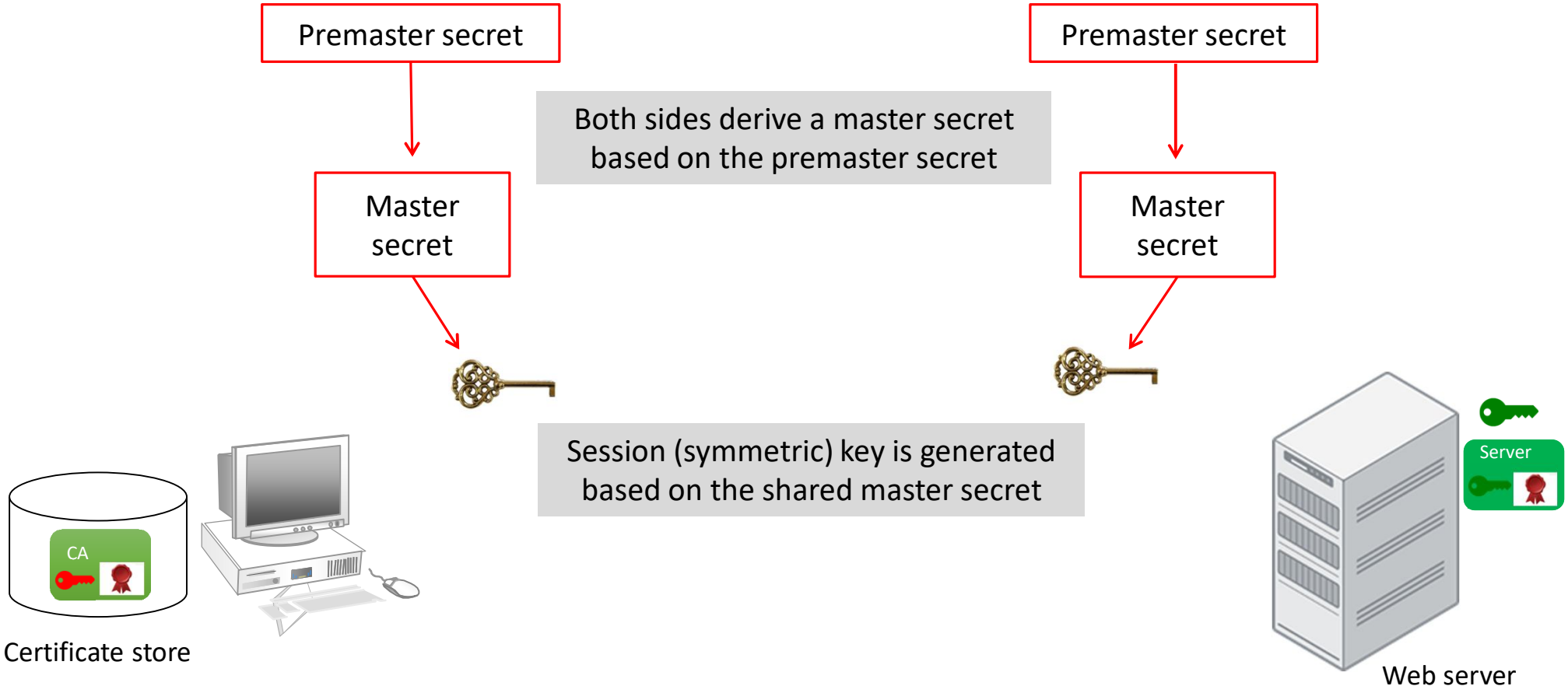
SSL/TLS Processing(2/3)

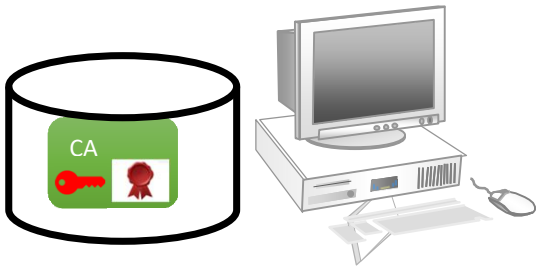


SSL/TLS Processing(3/3)

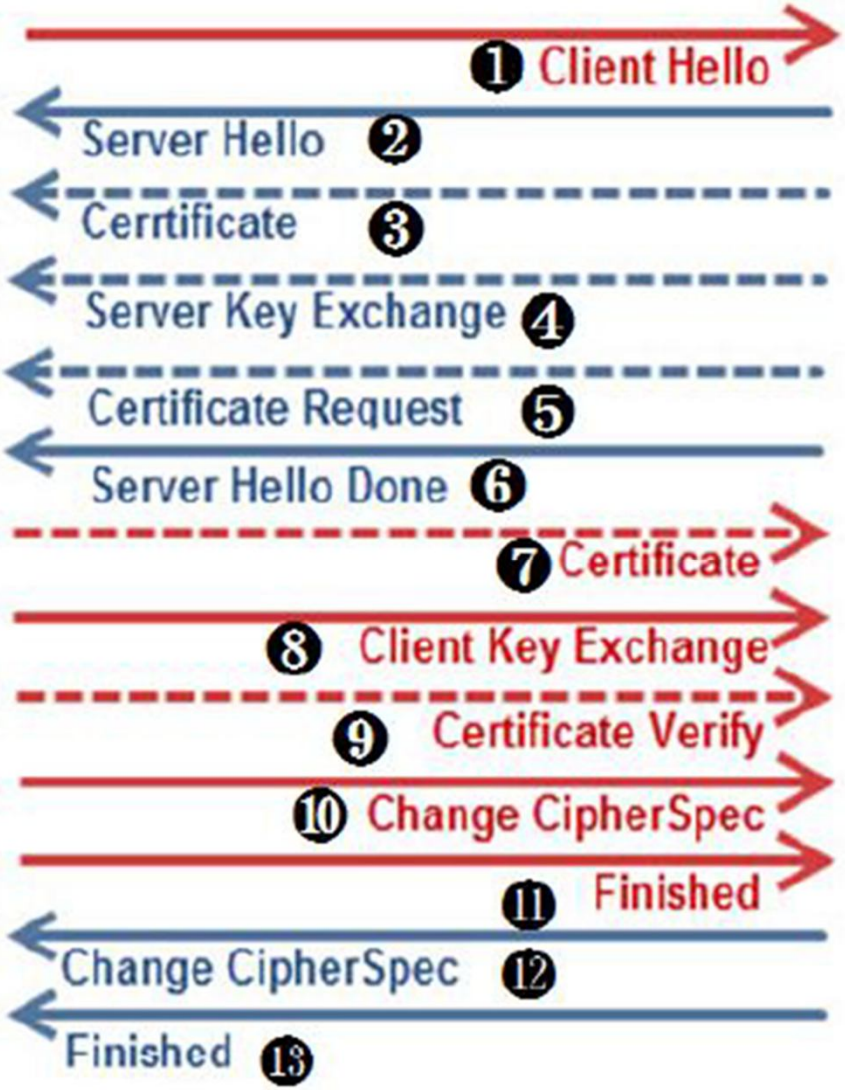


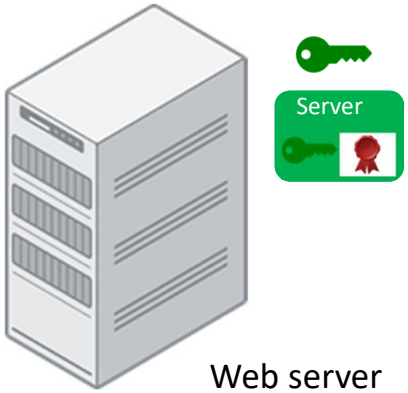

CLIENT
SERVER
SYN
SYN/ACK
ACK
ESTABLISHED
SSL Protocol version
Session ID
List of Cipher Suites
CLIENT HELLO Extensions
CLIENT HELLO
SSL Protocol version
Session ID
Selected Cipher
Server Certificate
SERVER HELLO Extensions
Client Certificate Request (Optional)
SERVER HELLO
Pre-master secret
Client Cert (If requested)
PRE MASTER SECRET
SESSION KEY CREATION
Server Authenticates the Client (Optional)
Master secret is used to generate Symmetric session keys
CLIENT FINISHED
SERVER FINISHED
EXCHANGE MESSAGES


Premaster secret
Premaster secret
Both sides derive a master secret based on the premaster secret
Master secret
Master secret
Session (symmetric) key is generated based on the shared master secret
CA
Server
Certificate store
Web server



Certificate store





Web server

1 단계. Client Hello message

```
▷ Frame 4: 235 bytes on wire (1880 bits), 235 bytes captured (1880 bits)
▷ Ethernet II, Src: Dell_c0:56:f0 (00:21:70:c0:56:f0), Dst: Cisco_31:07:33 (00:26:0b:31:07:33)
▷ Internet Protocol Version 4, Src: 172.16.0.122, Dst: 69.63.180.173
▷ Transmission Control Protocol, Src Port: 54595, Dst Port: 443, Seq: 1, Ack: 1, Len: 169
◢ Secure Sockets Layer
  ◢ TLSv1 Record Layer: Handshake Protocol: Client Hello
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 164
    ◢ Handshake Protocol: Client Hello
        Handshake Type: Client Hello (1)
        Length: 160
        Version: TLS 1.0 (0x0301)
      ▷ Random: 4bba350339dc8387b20a0c5cfa490f4807d25f05c6c4cbdc...
        Session ID Length: 0
        Cipher Suites Length: 70
      ▷ Cipher Suites (35 suites)
        Compression Methods Length: 1
      ▷ Compression Methods (1 method)
        Extensions Length: 49
      ▷ Extension: server_name (len=23)
      ▷ Extension: supported_groups (len=8)
      ▷ Extension: ec_point_formats (len=2)
      ▷ Extension: SessionTicket TLS (len=0)
```

content

Protocol Suite

```
◢ Secure Sockets Layer
  ◢ TLSv1 Record Layer: Handshake Protocol: Client Hello
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 164
    ◢ Handshake Protocol: Client Hello
        Handshake Type: Client Hello (1)
        Length: 160
        Version: TLS 1.0 (0x0301)
      ◢ Random: 4bba350339dc8387b20a0c5cfa490f4807d25f05c6c4cbdc...
          GMT Unix Time: Apr  6, 2010 04:07:47.000000000 대한민국 표준시
          Random Bytes: 39dc8387b20a0c5cfa490f4807d25f05c6c4cbdc71fa59e8...
        Session ID Length: 0
        Cipher Suites Length: 70
      ◢ Cipher Suites (35 suites)
          Cipher Suite: TLS_ECDHE_ECDSA_WITH_AES_256_CBC_SHA (0xc00a)
          Cipher Suite: TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)
          Cipher Suite: TLS_DHE_RSA_WITH_CAMELLIA_256_CBC_SHA (0x0088)
          Cipher Suite: TLS_DHE_DSS_WITH_CAMELLIA_256_CBC_SHA (0x0087)
          Cipher Suite: TLS_DHE_RSA_WITH_AES_256_CBC_SHA (0x0039)
          Cipher Suite: TLS_DHE_DSS_WITH_AES_256_CBC_SHA (0x0038)
          Cipher Suite: TLS_ECDH_RSA_WITH_AES_256_CBC_SHA (0xc00f)
          Cipher Suite: TLS_ECDH_ECDSA_WITH_AES_256_CBC_SHA (0xc005)
          Cipher Suite: TLS_RSA_WITH_CAMELLIA_256_CBC_SHA (0x0084)
          Cipher Suite: TLS_RSA_WITH_AES_256_CBC_SHA (0x0035)
          Cipher Suite: TLS_ECDHE_ECDSA_WITH_RC4_128_SHA (0xc007)
```

2 단계. Server Hello message

```
▷ Frame 5: 1003 bytes on wire (8024 bits), 1003 bytes captured (8024 bits)
▷ Ethernet II, Src: Cisco_31:07:33 (00:26:0b:31:07:33), Dst: Dell_c0:56:f0 (00:21:70:c0:56:f0)
▷ Internet Protocol Version 4, Src: 69.63.180.173, Dst: 172.16.0.122
▷ Transmission Control Protocol, Src Port: 443, Dst Port: 54595, Seq: 1, Ack: 170, Len: 937
◢ Secure Sockets Layer
  ◢ TLSv1 Record Layer: Handshake Protocol: Server Hello
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 74
    ◢ Handshake Protocol: Server Hello
        Handshake Type: Server Hello (2)
        Length: 70
        Version: TLS 1.0 (0x0301)
      ◢ Random: b9bb3b517aba70530291e8b0f97bb711647b94836658c94c...
          GMT Unix Time: Sep 28, 2068 19:56:17.000000000 대한민국 표준시
          Random Bytes: 7aba70530291e8b0f97bb711647b94836658c94c504630a2...
        Session ID Length: 32
        Session ID: 798e78f8199088e83fcf3e2ece32d14d26bc29eda5eb9149...
        Cipher Suite: TLS_RSA_WITH_RC4_128_MD5 (0x0004)
        Compression Method: null (0)
  ▷ TLSv1 Record Layer: Handshake Protocol: Certificate
  ▷ TLSv1 Record Layer: Handshake Protocol: Server Hello Done
```

3 단계. Certificate message

```
▷ TLSv1 Record Layer: Handshake Protocol: Server Hello
◢ TLSv1 Record Layer: Handshake Protocol: Certificate
    Content Type: Handshake (22)
    Version: TLS 1.0 (0x0301)
    Length: 844
  ◢ Handshake Protocol: Certificate
      Handshake Type: Certificate (11)
      Length: 840
      Certificates Length: 837
    ◢ Certificates (837 bytes)
        Certificate Length: 834
      ◢ Certificate: 3082033e308202a7a00302010202030c183f300d06092a86... (id-at-commonName=login.facebook.com,id-at-organizationalU
        ◢ signedCertificate
            version: v3 (2)
            serialNumber: 792639
          ▷ signature (sha1WithRSAEncryption)
          ▷ issuer: rdnSequence (0)
          ▷ validity
          ▷ subject: rdnSequence (0)
          ◢ subjectPublicKeyInfo
            ◢ algorithm (rsaEncryption)
                Algorithm Id: 1.2.840.113549.1.1.1 (rsaEncryption)
            ▷ subjectPublicKey: 30818902818100d6114e489ea6f3a3611ac38d0b3e46a30c...
          ▷ extensions: 5 items
        ◢ algorithmIdentifier (sha1WithRSAEncryption)
            Algorithm Id: 1.2.840.113549.1.1.5 (sha1WithRSAEncryption)
          Padding: 0
          encrypted: 36104b5d5b134d9fc9b0b9a47d1131e528992f9a6bf2f74f...
```

6 단계. Server Hello Done message

```
▷ Frame 5: 1003 bytes on wire (8024 bits), 1003 bytes captured (8024 bits)
▷ Ethernet II, Src: Cisco_31:07:33 (00:26:0b:31:07:33), Dst: Dell_c0:56:f0 (00:21:70:c0:56:f0)
▷ Internet Protocol Version 4, Src: 69.63.180.173, Dst: 172.16.0.122
▷ Transmission Control Protocol, Src Port: 443, Dst Port: 54595, Seq: 1, Ack: 170, Len: 937
◢ Secure Sockets Layer
  ▷ TLSv1 Record Layer: Handshake Protocol: Server Hello
  ▷ TLSv1 Record Layer: Handshake Protocol: Certificate
  ◢ TLSv1 Record Layer: Handshake Protocol: Server Hello Done
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 4
    ◢ Handshake Protocol: Server Hello Done
        Handshake Type: Server Hello Done (14)
        Length: 0
```

8 단계. Client Key(Premaster key) Exchange

```
▷ Frame 7: 248 bytes on wire (1984 bits), 248 bytes captured (1984 bits)
▷ Ethernet II, Src: Dell_c0:56:f0 (00:21:70:c0:56:f0), Dst: Cisco_31:07:33 (00:26:0b:31:07:33)
▷ Internet Protocol Version 4, Src: 172.16.0.122, Dst: 69.63.180.173
▷ Transmission Control Protocol, Src Port: 54595, Dst Port: 443, Seq: 170, Ack: 938, Len: 182
◢ Secure Sockets Layer
  ◢ TLSv1 Record Layer: Handshake Protocol: Client Key Exchange
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 134
    ◢ Handshake Protocol: Client Key Exchange
        Handshake Type: Client Key Exchange (16)
        Length: 130
      ◢ RSA Encrypted PreMaster Secret
          Encrypted PreMaster length: 128
          Encrypted PreMaster: 3b68c9a6fea0f7888813d309c8a1d81344b4b01f17d9a8ec...
  ◢ TLSv1 Record Layer: Change Cipher Spec Protocol: Change Cipher Spec
      Content Type: Change Cipher Spec (20)
      Version: TLS 1.0 (0x0301)
      Length: 1
      Change Cipher Spec Message
  ◢ TLSv1 Record Layer: Handshake Protocol: Encrypted Handshake Message
      Content Type: Handshake (22)
      Version: TLS 1.0 (0x0301)
      Length: 32
      Handshake Protocol: Encrypted Handshake Message
```

2. Zeek SSL 로그 필드

필드명	필드 설명
ts	시간정보
Uid	로그에 할당된 UID
id.orig_h	송신지 IP주소
id.orig_p	송신지 Port번호
id.resp_h	수신지 IP 주소
id.resp_p	수신지 Port 번호
version	SSL 사용버전
cipher	비밀성, 무결성 암호 알고리즘 명세
server_name	접속 서버 도메인
established	연결여부
cert_chain_fuids	인증서 UID 인증서를 구분할 수 있는 필드 x.509.log의 uid와 연결

3. Zeek X.509 로그 필드

필드명	필드 설명
Certificate.subject	인증서 사용 주체
Certificate.issuer	인증서를 발행한 CA
Certificate.not_valid_before	인증서 시작인
Certificate.not_valid_after	인증서 종료일

2. SSL & X.509 네트워크 현황분석

- Top 10 접속 도메인
- 인증서 만료 임박 사이트

❶ Top 10 접속 도메인

- 암호화로 SNI(Server Name Identification)을 이용하여 도메인명을 검색

```
index=ssllog sourcetype=ssllog domain!="-"
| top domain showperc=false
```

domain	count
outlook.office365.com	386146
dev-prod05.conferdeploy.net	341658
config.edge.skype.com	53713
mobile.pipe.aria.microsoft.com	53225
v10c.events.data.microsoft.com	47278
c.urs.microsoft.com	37169
nexusrules.officeapps.live.com	32527
sb-talk.kakao.com	30996
t1.daumcdn.net	30386
nexus.officeapps.live.com	30346

❷ 인증서 만료 임박 사이트

```
index=ssllog sourcetype=ssllog eventtype=dst_internet domain!="-"
| join type=inner cert_chain_fuids max=0
    [ search index=ssllog sourcetype=x509
    | eval expire_date=strftime(cert_not_valid_after, "%Y-%m-%d")
    | eval snapshot_expired = strftime(relative_time(now( ), "+2w@"), "%Y-%m-%d")
    | eval today=strftime(now(), "%Y-%m-%d")
    | where expire_date >= today AND snapshot_expired > expire_date
    | rename uid AS cert_chain_fuids
    | table cert_chain_fuids, expire_date, snapshot_expired, ex_condition, va_condition, today]
| eval x509_domain_expiry=domain."::".expire_date
| top limit=0 showperc=f x509_domain_expiry
```

3. SSL & X.509 이상징후 분석

- 인증서 만료 SSL 통신
- Self-signed 인증서 사용

인증서 오류 원인

- 인증서 발급 시 도메인과 실제 도메인의 불일치
- 인증서의 유효기간이 지난 경우
- 인증서 만료가 임박하면 서버에 새로운 인증서를 설치해서 유효기간을 연장해야 함
- 인증서 만료가 얼마 남지 않은 서비스를 사전에 탐지 필요

- 인증서 오류는 암호통신 자체의 신뢰성을 무너뜨릴 수 있음
- 인증서는 유효 기간이 만료된다고 인증서 자체의 기능이 사라지는 것은 아님
- 인증서가 만료되어도 암호화 통신을 수행

❶ 인증서 만료 SSL 통신

```
index=ssllog sourcetype=ssllog eventtype=dst_internet
| join type=inner cert_chain_fuids max=0
    [ search index=ssllog sourcetype=x509
    | eval expire_date=strftime(cert_not_valid_after, "%Y-%m-%d")
    | eval today=strftime(now(), "%Y-%m-%d")
    | eval isExpired = if(expired_date <today, "expired","Not Yet")
    | where isExpired="expired"
    | fields uid
    | rename uid AS cert_chain_fuids
    | table cert_chain_fuids ]
| table src, dst, domain, subject
```

* 인증서 정보 로그를 SSL로그와 결합하면 사용주체와 도메인이 다른 경우 추출 가능

❷ Self-Singed 인증서 사용

```
index=ssllog sourcetype=ssllog (client_issuer!="-" AND client_subject!="-")
| eval txt = if(client_issuer == client_subject,"SELF","NO")
| where txt = "SELF"
| table client_issuer, client_subject, domain
| dedup domain
```

client_issuer	client_subject	domain
C=US,ST=MN,OU=TEST,O=Code42,CN=861493721636242397	C=US,ST=MN,OU=TEST,O=Code42,CN=861493721636242397	-